COMPTIA SECURITY+ SY0-701 | DOMÍNIO 4 · OPERAÇÕES DE SEGURANÇA (28%)

Security+ 4.5 · Monitoring Data

Mestre CyberSec · **Aula 4.5 — Monitoring Data** (7:25) · Assistir Vídeo no YouTube ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

Resumo Executivo da Aula: DLP (impede dado sensível SAIR — por e-mail/USB/upload); FIM (alerta hash mudou em arquivo crítico); USB blocking (bloqueia armazenamento externo); DLP in use (confidential computing).

💡 Highlights que a prova CompTIA cobra

- DLP: monitora e BLOQUEIA dado saindo por email/USB/upload
- FIM: alerta qualquer arquivo crítico modificado

🎯 Dicas de Prova & Cenários Típicos da Banca

- 'prevents sensitive data from leaving the organization'=DLP

🧯 Além do Vídeo: Conceitos Oficiais, Siglas e Armadilhas (Seção 4.5 — Monitoring Data)

Por que este aprofundamento é cobrado na prova?: O vídeo resume os tópicos práticos, mas o exame CompTIA SY0-701 cobra discernimento técnico rigoroso sobre as tecnologias e protocolos específicos desta seção:

• Prevenção contra Perda de Dados (DLP)

Controle de segurança que monitora e BLOQUEIA dados sensíveis de saírem da organização por e-mail, USB, uploads na nuvem ou outros canais. Os agentes DLP rodam em endpoints, servidores (rede) e na nuvem, inspecionando o conteúdo contra padrões ou políticas definidas.

⚠ ***Armadilha CompTIA:*** *A frase-chave da prova: 'prevents sensitive data from leaving the organization' = DLP. Não confunda com IPS/Firewall (bloqueiam ataques na rede, não vazamento de conteúdo), nem com FIM (integridade de arquivos, não saída de dados).*

• Monitoramento de Integridade de Arquivos (FIM)

Controle que ALERTA quando arquivos críticos (SO, aplicações, configurações) são modificados, comparando o hash atual de cada arquivo com uma base de hashes de linha de base (baseline) conhecidos como bons.

⚠ ***Armadilha CompTIA:*** *Gatilho: 'alert when a critical/system file is modified' ou 'detect unauthorized changes to system files' = FIM. Palavra-associada: hash/baseline. Não confunda com DLP (evita EXFILTRAÇÃO) nem com SIEM (agrega logs, não valida integridade de arquivo).*

• Dados em Movimento / Em Trânsito

Dados ativamente trafegando pela rede (e-mail, uploads, transferências); um dos três estados dos dados, monitorado por agentes DLP de rede que inspecionam o tráfego em tempo real.

⚠ ***Armadilha CompTIA:*** *Se a questão diz 'data crossing the network / being transmitted' → DATA IN MOTION. O SY0-701 exige distinguir os 3 estados: em movimento (rede), em repouso (armazenamento) e em uso (processamento na memória).*

• Dados em Repouso

Dados armazenados em mídias como HDs, SSDs ou sistemas de backup; protegidos por agentes DLP de endpoint/servidor que escaneiam arquivos armazenados, além de criptografia de disco e banco de dados.

⚠ ***Armadilha CompTIA:*** *Se a questão menciona 'data stored on a drive/database' → DATA AT REST. Termo clássico associado: full-disk/database encryption. Diferente de 'in use' (em processamento ativo na memória).*

• Dados em Uso

Dados ativamente processados na memória por uma aplicação; destacado como estado distinto no SY0-701 e protegido por tecnologias emergentes como a computação confidencial.

⚠ ***Armadilha CompTIA:*** *Novidade do SY0-701: 'data in use' entrou explicitamente como estado dos dados. Se a questão diz 'data being processed/in memory' → DATA IN USE (e a tecnologia associada é confidential computing, NÃO criptografia*

convencional).

• Bloqueio de USB (Prevenção de Ações de Dados)
Controle de dispositivo no endpoint que impede o uso de mídias removíveis/externas, bloqueando tanto a exfiltração de dados via pen-drives quanto malware introduzido por dispositivos desconhecidos; alguns fabricantes chamam de Data Action Prevention.

⚠️ ***Armadilha CompTIA:*** *Gatilho: 'users should not be able to connect external storage drives' = USB blocking — que é uma implementação específica de DLP no endpoint. Se a pergunta fala de bloquear O DISPOSITIVO → USB blocking; se fala de inspecionar o CONTEÚDO que sai → DLP.*

• Computação Confidencial (DLP em Uso)
Abordagem baseada em nuvem, geralmente usando enclaves seguros de hardware, que protege e criptografa os dados enquanto estão ativamente processados na memória — estendendo a proteção DLP ao estado 'dados em uso'.

⚠️ ***Armadilha CompTIA:*** *Na prova, 'data protected during processing / inside a secure enclave / trusted execution environment' = confidential computing (DLP in use). Distinga da criptografia em repouso (disk) e em trânsito (TLS) — essa cobre exatamente o estado que as outras duas não cobrem.*

• Hashing (Comparação de Linha de Base)
Cálculo de digest criptográfico de mão única usado pelo FIM para criar 'impressões digitais' de arquivos críticos; uma base baseline de hashes salva é comparada aos hashes atuais, e qualquer diferença indica alteração no arquivo.

⚠️ ***Armadilha CompTIA:*** *'Compare the hash against the baseline to detect the file change' = FIM. Lembre-se: hash é ONE-WAY (não é criptografia, não é reversível) — errado falar 'encrypt the file to check integrity'. A alteração de UM byte já gera hash totalmente diferente.*

🏛️ Visão Didática, Analogias & Análise de Governança (GRC)

📌 Metadados de Fluxo de Rede: NetFlow & IPFIX (O Extrato Telefônico da Rede)

🏠 **Analogia Intuitiva:** Imagine a fatura detalhada da sua linha telefônica: ela lista exatamente a data, a hora em que você ligou, para qual número discou, quanto tempo a ligação durou e quantos megabytes foram consumidos, mas ela NÃO grava o áudio do que você falou na conversa. O NetFlow e o IPFIX fazem exatamente isso com a rede: registram o IP de origem, IP de destino, portas lógicas, protocolo e contagem de bytes e pacotes sem armazenar o conteúdo dos arquivos. Isso permite monitorar meses de tráfego consumindo pouquíssimo espaço em disco.

🔍 **Causa Raiz / Por que foi criado:** Salvar todos os pacotes completos trafegando em uma rede corporativa gigabit consome centenas de terabytes por dia. Metadados de fluxo fornecem visibilidade estatística massiva com fração minúscula de custo de armazenamento e CPU.

🛡️ **Visão do Auditor de GRC:** Auditoria da ativação de exportação de NetFlow/IPFIX em todos os switches core e roteadores perimetrais; envio seguro dos fluxos para coletores centralizados com retenção mínima de 180 dias para análises forenses retrospectivas.

⚠️ **Como cai na Prova CompTIA:** Gatilho de prova: 'analyzing network traffic patterns, volume trends, and source/destination IP pairs WITHOUT capturing payload contents' = NetFlow / IPFIX. Pegadinha: IPFIX é o padrão aberto IETF baseado no NetFlow v9 da Cisco.

📌 Captura Completa de Pacotes (PCAP / Full Packet Capture) - A Gravação em Vídeo 4K

🏠 **Analogia Intuitiva:** Diferente do extrato telefônico simples, a captura de pacotes (PCAP) é a gravação em vídeo e áudio em altíssima definição de tudo o que foi falado dentro da sala. Se um espião sussurrou uma senha secreta, copiou uma imagem confidencial ou enviou um comando de destruição, o arquivo PCAP preserva cada bit, cada cabeçalho e cada caractere exatamente como ele viajou pelo fio. É a prova forense definitiva e irrefutável.

🔍 **Causa Raiz / Por que foi criado:** Metadados de fluxo mostram apenas que 500 Megabytes foram transmitidos para um IP desconhecido, mas apenas o PCAP permite que o analista abra os pacotes e descubra exatamente qual documento confidencial foi roubado.

🛡️ **Visão do Auditor de GRC:** Fiscalização de controles de acesso rígidos sobre repositórios de arquivos PCAP devido ao risco iminente de exposição de dados pessoais e credenciais em trânsito; limitação de retenção com descarte automatizado após encerramento do incidente.

⚠️ **Como cai na Prova CompTIA:** Gatilho de prova: 'capturing raw network frames including packet headers and data payloads for protocol analysis in Wireshark' = Packet Capture (PCAP) / Packet Analysis.

📌 Anomalias de Protocolo & Detecção Heurística (O Pacote Fora do Padrão)

🏠 **Analogia Intuitiva:** Imagine uma agência de correios onde todas as cartas normais pesam 20 gramas e medem 15 centímetros de comprimento. De repente, chega um pacote com uma etiqueta dizendo 'carta postal comum', mas o objeto tem 3 metros de altura, pesa 40 quilos e faz barulho de engrenagens ligadas por dentro. O inspetor não precisa de um manual de vírus para saber que aquilo está completamente fora do padrão de uma carta normal (anomalia de protocolo) — como um malware que esconde comandos e dados roubados dentro de consultas DNS aparentemente inofensivas (DNS Tunneling).

🔍 **Causa Raiz / Por que foi criado:** Hackers modernos utilizam técnicas de evasão mascarando tráfego malicioso e canais de comando e controle (C2) dentro de protocolos legítimos e abertos na rede corporativa (como DNS na porta 53 ou HTTPS na porta 443).

🛡️ **Visão do Auditor de GRC:** Implementação de sistemas NIDS/NIPS com análise heurística comportamental e decodificadores de protocolo; criação de alertas automatizados para requisições DNS com strings em Base64 de tamanho excessivo ou tráfego HTTP em portas não convencionais.

⚠️ **Como cai na Prova CompTIA:** Gatilho de prova: 'detecting malicious data exfiltration concealed within standard DNS requests' = DNS Tunneling / Protocol Anomaly. Gatilho: 'identifying attacks based on deviation from baseline RFC protocol standards' = Heuristic / Anomaly-based analysis.

📌 Sensores de Rede: TAPs de Hardware vs Espelhamento de Portas (SPAN)

🏠 **Analogia Intuitiva:** Para monitorar as conversas em uma linha telefônica analógica importante, você tem duas opções: pedir para a telefonista fazer uma cópia por escrito de cada ligação (Port Mirroring / SPAN feito pelo switch de rede) ou grampear diretamente o fio de cobre com um grampo físico (Network TAP). Se a telefonista ficar sobrecarregada com 50 chamadas ao mesmo tempo, ela começa a jogar conversas fora (o switch descarta pacotes de monitoramento para salvar a CPU). Já o grampo físico no fio de cobre nunca se cansa, não depende do switch e copia 100% dos sussurros sem perder uma única sílaba.

🔍 **Causa Raiz / Por que foi criado:** Sistemas de detecção de intrusão (IDS) e sensores forenses precisam de cópias completas do tráfego de rede para análise contínua sem introduzir latência ou interferir na comunicação original dos computadores.

🛡️ **Visão do Auditor de GRC:** Auditoria de arquitetura de monitoramento: exigência de TAPs de fibra óptica em troncos de agregação de alta capacidade (10Gbps+); auditoria de portas SPAN em switches de borda para assegurar que não haja descarte de pacotes por saturação de buffer.

⚠️ **Como cai na Prova CompTIA:** Gatilho de prova: 'hardware device spliced directly into network cabling to duplicate traffic for security analysis without packet loss' = Network TAP. Gatilho: 'switch capability copying traffic from designated VLANs to a diagnostic port' = Port Mirroring / SPAN.

⚡ TABELA DE FIXAÇÃO RÁPIDA PARA O EXAME (CHEAT SHEET)

Cenário Típico de Exame / Situação Prática	Conceito Técnico & Resposta da Banca
Coleta estatística de registros de tráfego de rede (endereços IP, portas, protocolos e volume) sem capturar a carga de dados	**NetFlow / IPFIX**
Gravação integral do tráfego de rede incluindo cabeçalhos completos e cargas úteis para análise forense profunda	**Captura Completa de Pacotes (PCAP)**
Técnica de invasão que esconde tráfego malicioso e dados confidenciais exfiltrados dentro de consultas e respostas DNS legítimas	**Tunelamento de DNS (DNS Tunneling)**
Recurso de software em switch gerenciável que copia frames de portas de origem para uma porta de monitoramento dedicada	**Espelhamento de Portas (Port Mirroring / SPAN)**
Dispositivo de hardware passivo instalado diretamente no cabeamento físico para clonar todo o tráfego sem queda de desempenho	**TAP de Rede (Network TAP)**
Identificação de ataques cibernéticos baseada na violação das normas técnicas RFC e padrões comportamentais esperados	**Detecção de Anomalias de Protocolo**

✅ Perguntas de Treino Comentadas (10 Questões de Cenários Reais)

Cenários autênticos alinhados aos objetivos do exame. O gabarito com análise completa dos distratores encontra-se ao final.

QUESTÃO 1 · CENÁRIO DE EXAME

Um administrador de folha de pagamento de uma empresa de manufatura foi pego enviando por e-mail uma planilha contendo os números de identificação e os dados bancários de 4.000 funcionários para um endereço de webmail pessoal, e a transferência passou completamente despercebida. O CISO designa à equipe de segurança a implantação de um controle no gateway de e-mail que detecte e bloqueie mensagens de saída contendo dados pessoais de funcionários antes que saiam da organização. Qual tecnologia melhor atende a esse requisito?

A) Detecção e resposta de endpoints (EDR) com analítica comportamental em todos os endpoints corporativos gerenciados

B) Monitoramento de integridade de arquivos (FIM) no servidor de e-mail mantendo telemetria e monitoramento contínuos

C) Prevenção de perda de dados (DLP) baseada em rede com inspeção de conteúdo de saída

D) Monitoramento de atividade de banco de dados no sistema de folha de pagamento em todos os clusters híbridos locais e em nuvem

QUESTÃO 2 · CENÁRIO DE EXAME

Um analista de segurança descobre que o rodapé da página inicial pública de e-commerce da empresa contém um bloco de script ofuscado que nenhum desenvolvedor adicionou, indicando que o arquivo de conteúdo web foi adulterado. Esses arquivos de conteúdo são registrados como ativos críticos e só podem ser alterados por requisições de mudança aprovadas. Qual controle, se adequadamente configurado, teria gerado um alerta no momento em que o arquivo foi modificado?

A) Monitoramento de integridade de arquivos que compara o hash atual do arquivo com uma linha de base armazenada

B) DLP baseada em rede inspecionando tráfego HTTP POST de saída eliminando pontos únicos de falha operacional

C) Criptografia de disco completo no servidor web em todos os clusters híbridos locais e em nuvem

D) Mascaramento de dados aplicado a exportações de banco de dados sem interromper a disponibilidade das cargas de produção

QUESTÃO 3 · CENÁRIO DE EXAME

Após um incidente em que um terceirizado copiou milhares de registros de pacientes de uma estação de trabalho do hospital para um pen drive pessoal, o escritório de privacidade exige um controle técnico que impeça que dados de pacientes sejam gravados em qualquer mídia removível. A equipe deve continuar usando teclados, mouses e impressoras USB padrão. Qual solução atende aos dois requisitos?

A) Desabilitar todas as portas USB na configuração da BIOS de cada estação de trabalho eliminando pontos únicos de falha operacional

B) Agente DLP de endpoint com prevenção de ações de dados (USB blocking) que bloqueia gravações em dispositivos de armazenamento removíveis

C) FIM implantado no banco de dados de prontuários eletrônicos sem interromper a disponibilidade das cargas de produção

D) Criptografia de disco completo exigida em todos os notebooks corporativos aplicando menor privilégio e reduzindo superfícies de ataque

QUESTÃO 4 · CENÁRIO DE EXAME

Uma fintech opera um serviço que processa solicitações de empréstimo. Novas regulamentações exigem que os dados financeiros dos clientes permaneçam protegidos mesmo enquanto os cálculos são executados ativamente nos servidores, pois atacantes demonstraram a capacidade de coletar segredos em texto claro diretamente da memória de processos. A equipe de engenharia deve selecionar uma abordagem em que o cálculo ocorra dentro de uma memória protegida que nem o sistema operacional hospedeiro nem o hypervisor conseguem ler. Qual tecnologia devem escolher?

A) TLS 1.3 com autenticação mútua para todo o tráfego de API em todos os clusters híbridos locais e em nuvem

B) Criptografia de disco completo AES-256 nos servidores de processamento sem interromper a disponibilidade das cargas de produção

C) FIM nos binários da aplicação e nos arquivos de configuração aplicando menor privilégio e reduzindo superfícies de ataque

D) Computação confidencial usando ambientes confiáveis de execução (secure enclaves) com suporte de hardware

QUESTÃO 5 · CENÁRIO DE EXAME

Uma empresa replica registros de clientes todas as noites do seu data center local para um site de recuperação de desastres, e o arquiteto de segurança determinou um túnel IPsec para proteger essa transferência noturna. Durante uma revisão de mapeamento de controles, o analista precisa classificar qual estado dos dados o túnel IPsec está protegendo.

A) Dados em movimento (data in motion)

B) Dados em repouso (data at rest) aplicando menor privilégio e reduzindo superfícies de ataque

C) Dados em uso (data in use) através de pipelines automatizados de configuração

D) Dados em custódia (data in escrow)

QUESTÃO 6 · CENÁRIO DE EXAME

Uma auditoria interna levantou preocupações de que planilhas contendo números completos de cartões de crédito estejam armazenadas em compartilhamentos de arquivos departamentais, em violação à política de classificação de dados. A direção quer uma ferramenta que varra continuamente esses repositórios, identifique arquivos cujo conteúdo corresponda a padrões de cartões de pagamento e gere apontamentos para remediação. Qual capacidade a equipe de segurança deve implantar?

A) FIM monitorando alterações nos compartilhamentos de arquivos aplicando menor privilégio e reduzindo superfícies de ataque

B) DLP baseada em rede monitorando uploads web de saída através de pipelines automatizados de configuração

C) DLP em modo de dados em repouso (data at rest), configurada para varrer compartilhamentos de arquivos em busca de conteúdo sensível

D) DLP de endpoint com bloqueio de USB habilitado utilizando perfis padronizados de automação de segurança

QUESTÃO 7 · CENÁRIO DE EXAME

Uma empresa implantou FIM em seus servidores críticos. Todos os meses, após a janela de patch de rotina, os analistas são inundados com centenas de alertas de integridade que remontam a arquivos do sistema operacional legitimamente atualizados, dificultando identificar incidentes reais. Qual é a maneira mais eficaz de reduzir esses falsos positivos mantendo a proteção intacta?

A) Trocar o algoritmo de hash de SHA-256 para SHA-512 através de pipelines automatizados de configuração

B) Excluir todos os diretórios do sistema operacional do monitoramento do FIM assegurando conformidade rigorosa de retenção de logs

C) Converter o FIM do modo detecção para o modo bloqueio utilizando perfis padronizados de automação de segurança

D) Verificar os arquivos corrigidos e atualizar a linha de base do FIM pelo processo de gerenciamento de mudanças após cada ciclo de patch

QUESTÃO 8 · CENÁRIO DE EXAME

O escritório de conformidade quer que a DLP seja aplicada em e-mails de saída, mas a equipe de mensageria adverte que regras agressivas e não testadas podem colocar em quarentena correspondências legítimas de clientes e interromper o negócio. A diretoria exige que a proteção seja implantada sem interromper o fluxo de e-mails. Como a equipe de segurança deve dividir a implantação em fases?

A) Habilitar o bloqueio pleno de todas as políticas desde o primeiro dia e ajustar conforme surgirem reclamações assegurando conformidade rigorosa de retenção de logs

B) Começar em modo somente detecção para coletar e ajustar as correspondências das regras e habilitar o bloqueio depois que os falsos positivos forem reduzidos

C) Implantar agentes DLP apenas nos endpoints dos executivos e pular o gateway de e-mail prevenindo desvios não autorizados de configuração nos nós

D) Restringir a varredura a mensagens com anexos maiores que 25 MB para reduzir a carga em todos os endpoints corporativos gerenciados

QUESTÃO 9 · CENÁRIO DE EXAME

Uma empresa de design de produtos descobriu que um engenheiro em processo de desligamento enviou arquivos CAD proprietários para uma conta de armazenamento em nuvem pessoal a partir de uma estação de trabalho corporativa. Os logs do proxy web da empresa não contêm eventos bloqueados para a sessão, porque os arquivos foram transmitidos por uma conexão HTTPS criptografada e o proxy nunca avaliou seu conteúdo. A empresa precisa de um controle que reconheça os dados classificados da empresa e impeça envios futuros deles para serviços de nuvem não autorizados. Qual solução melhor enfrenta esse caminho de exfiltração?

A) DLP de rede em conjunto com inspeção SSL/TLS no gateway para bloquear uploads que correspondam às classificações de dados

B) FIM no repositório de arquivos de design prevenindo desvios não autorizados de configuração nos nós

C) Criptografia de disco completo em todas as estações de trabalho em todos os endpoints corporativos gerenciados

D) Enclaves de computação confidencial na fazenda de renderização de design mantendo telemetria e monitoramento contínuos

QUESTÃO 10 · CENÁRIO DE EXAME

Durante uma apresentação ao conselho, o CISO da área de saúde descreve a pilha de proteção de dados: criptografia de disco completo nos servidores de banco de dados, túneis IPsec para replicação de registros entre sites e um ambiente confiável de execução para o motor de processamento de sinistros. Um membro do conselho pergunta qual estado dos dados cada controle protege, na ordem apresentada. Como o CISO deve responder?

A) Dados em movimento, dados em repouso, dados em uso

B) Dados em uso, dados em movimento, dados em repouso

C) Dados em repouso, dados em uso, dados em movimento

D) Dados em repouso, dados em movimento, dados em uso

GABARITO COMENTADO COM ANÁLISE DE DISTRATORES

Questão 1: Alternativa C — Prevenção de perda de dados (DLP) baseada em rede com inspeção de conteúdo de saída

A DLP inspeciona o conteúdo conforme ele sai da organização e pode bloquear ou colocar em quarentena e-mails cujo texto corresponde a padrões de dados sensíveis, como números de identificação e contas bancárias, atuando diretamente sobre os dados em movimento (data in motion) pelo canal de exfiltração explorado. A EDR foca em comportamentos maliciosos nos endpoints, não no conteúdo das mensagens. O FIM alerta quando arquivos críticos são alterados, mas não inspeciona o conteúdo de e-mails. O monitoramento de atividade de banco de dados observa consultas internas ao SGBD e não impede que um usuário envie por e-mail dados exportados.

Questão 2: Alternativa A — Monitoramento de integridade de arquivos que compara o hash atual do arquivo com uma linha de base armazenada

O FIM registra um hash criptográfico de linha de base dos arquivos críticos e recalcula o hash periodicamente ou a cada acesso; qualquer modificação no arquivo, incluindo um script injetado, produz um hash diferente e dispara um alerta para investigação. A DLP de rede monitora dados sensíveis saindo da rede, não mudanças em arquivos específicos. A criptografia de disco protege a confidencialidade dos dados armazenados, mas não revela se um arquivo foi alterado. O mascaramento de dados oculta valores sensíveis em cópias de não produção e não detecta adulteração de conteúdo web.

Questão 3: Alternativa B — Agente DLP de endpoint com prevenção de ações de dados (USB blocking) que bloqueia gravações em dispositivos de armazenamento removíveis

O bloqueio de USB, implantado como política de prevenção de ações de dados (data action prevention) da DLP no endpoint, bloqueia as ações de gravação e cópia em dispositivos de armazenamento removíveis, mantendo teclados e mouses USB totalmente utilizáveis. Desabilitar as portas USB na BIOS também quebraria teclados, mouses e impressoras conectados via USB. O FIM detecta alterações em arquivos e não impede a cópia para um pen drive. A criptografia de disco protege dados se o notebook for perdido, mas não impede a cópia de registros para mídia removível.

Questão 4: Alternativa D — Computação confidencial usando ambientes confiáveis de execução (secure enclaves) com suporte de hardware

A computação confidencial é o controle de DLP 'em uso' (data in use): protege os dados enquanto eles são processados ativamente, executando os cálculos dentro de um ambiente confiável de execução (TEE) ou enclave seguro baseado em hardware, onde a memória é criptografada e isolada do SO hospedeiro e do hypervisor. O TLS protege dados em movimento entre sistemas e a criptografia de disco protege dados em repouso; nenhum dos dois impede texto claro na memória durante o processamento. O FIM apenas detecta alterações não autorizadas em arquivos.

Questão 5: Alternativa A — Dados em movimento (data in motion)

Dados em movimento (data in motion, ou em trânsito) são dados trafegando pela rede. A criptografia aplicada a um túnel IPsec site-a-site protege os registros enquanto se movem entre o data center e o site de DR. Dados em repouso abrangem dados armazenados protegidos por criptografia de disco ou de banco de dados, e dados em uso abrangem dados processados ativamente na memória, protegidos por computação confidencial. Dados em custódia (escrow) referem-se a uma cópia dos dados mantida por um terceiro neutro como salvaguarda contratual, e não a uma proteção aplicada ao tráfego de rede.

Questão 6: Alternativa C — DLP em modo de dados em repouso (data at rest), configurada para varrer compartilhamentos de arquivos em busca de conteúdo sensível

A DLP atua sobre os três estados dos dados. O modo de dados em repouso varre repositórios armazenados, como compartilhamentos de arquivos e bancos de dados, comparando o conteúdo dos arquivos com regras como padrões de cartões de crédito e relatando violações. O FIM alertaria sobre modificações, mas não informa se arquivos armazenados contêm números de cartão. A DLP de rede monitora dados cruzando a rede, não o que já está nos repositórios. O bloqueio de USB impede cópias para mídia removível, mas não descobre dados armazenados indevidamente.

Questão 7: Alternativa D — Verificar os arquivos corrigidos e atualizar a linha de base do FIM pelo processo de gerenciamento de mudanças após cada ciclo de patch

Uma linha de base só é válida até que ocorra uma mudança autorizada. Quando o patching altera legitimamente os arquivos do sistema, os hashes armazenados deixam de coincidir; por isso o procedimento correto é verificar as atualizações e refazer a linha de base (recalcular e atualizar os hashes armazenados) por meio do processo formal de gerenciamento de mudanças. Um algoritmo de hash diferente continuará divergindo após as atualizações. Excluir

diretórios do SO remove cobertura valiosa, pois binários do sistema são alvos preferenciais de atacantes. O FIM é um controle detetive que alerta sobre mudanças; ele não bloqueia modificações.

Questão 8: Alternativa B — Começar em modo somente detecção para coletar e ajustar as correspondências das regras e habilitar o bloqueio depois que os falsos positivos forem reduzidos

A implantação da DLP deve começar em modo de monitoramento/detecção, que registra violações em potencial sem afetar a entrega. Os analistas usam as correspondências observadas para ajustar as regras e eliminar falsos positivos, e o bloqueio só é habilitado após o conjunto de regras se mostrar confiável. O bloqueio imediato arrisca interromper e-mails legítimos do negócio desde o primeiro dia. Implantar apenas nos executivos deixa o principal canal de exfiltração desprotegido. A filtragem por tamanho perderia a grande maioria dos e-mails de tamanho normal contendo dados sensíveis.

Questão 9: Alternativa A — DLP de rede em conjunto com inspeção SSL/TLS no gateway para bloquear uploads que correspondam às classificações de dados

A DLP de rede, implantada com inspeção SSL/TLS para enxergar dentro das sessões criptografadas, compara os uploads de saída com regras de conteúdo (tipos de arquivo, padrões de dados, classificações) e bloqueia transferências para destinos não autorizados, como armazenamento em nuvem pessoal. O FIM detecta alterações nos arquivos do repositório, mas não impede o upload. A criptografia de disco protege dados em repouso na estação de trabalho. A computação confidencial protege os dados durante o processamento e não controla uploads de saída.

Questão 10: Alternativa D — Dados em repouso, dados em movimento, dados em uso

A criptografia de disco completo protege os dados armazenados, ou seja, dados em repouso. O túnel IPsec protege os registros enquanto são replicados entre os sites, ou seja, dados em movimento. O ambiente confiável de execução protege os dados de sinistros enquanto o motor os processa ativamente, ou seja, dados em uso. Juntos, os três controles fornecem cobertura sobre os três estados dos dados.